Forge Train Braking and Control Commands over the End-of-Train / Head-of-Train Radio Link
  Trigger sudden unintended braking on a moving freight train to cause derailment, operational chaos, or physical damage
    End-of-Train / Head-of-Train Device (EoT/HoT, 'FRED')
      CWE-353: Missing Support for Integrity Check
      CWE-294: Authentication Bypass by Capture-replay
      CWE-346: Origin Validation Error
    Locomotive Brake Control and Air Brake Interface
      CWE-345: Insufficient Verification of Data Authenticity
  Suppress legitimate braking commands to defeat the train's safety response and endanger operations
    End-of-Train / Head-of-Train Device (EoT/HoT, 'FRED')
      CWE-940: Improper Verification of Source of a Communication Channel
      CWE-300: Channel Accessible by Non-Endpoint
Halt Trains by Spoofing Analog Trackside and Cab Radio Emergency-Stop Signals
  Cause nationwide service disruption and sow public fear by remotely forcing trains to emergency-stop with cheap radio equipment
    Analog Train Radio and Radio-Stop System (VHF 150 MHz)
      CWE-306: Missing Authentication for Critical Function
      CWE-290: Authentication Bypass by Spoofing
    GSM-R Cab Radio and Bearer Network
      CWE-327: Use of a Broken or Risky Cryptographic Algorithm
      CWE-940: Improper Verification of Source of a Communication Channel
Spoof or Tamper with Trackside Signalling to Issue Unsafe Movement Authorities
  Feed false position or movement-authority data into train control to cause overspeed, collision, or wrong-route movement
    EuroBalise / Trackside Spot-Transmission System
      CWE-345: Insufficient Verification of Data Authenticity
      CWE-290: Authentication Bypass by Spoofing
    EuroRadio / ETCS Train-to-Trackside Messaging
      CWE-327: Use of a Broken or Risky Cryptographic Algorithm
      CWE-294: Authentication Bypass by Capture-replay
    Interlocking and Signalling Control System
      CWE-287: Improper Authentication
      CWE-20: Improper Input Validation
Compromise Onboard Train Networking and Gateway Devices to Pivot into Vehicle Systems
  Gain remote code execution on the onboard train router/gateway to establish persistence and move toward control-adjacent networks
    Onboard Train Router / Cellular Gateway
      CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')
      CWE-287: Improper Authentication
      CWE-1395: Dependency on Vulnerable Third-Party Component
      CWE-829: Inclusion of Functionality from Untrusted Control Sphere
    Train Control & Monitoring System (TCMS) Network
      CWE-923: Improper Restriction of Communication Channel to Intended Endpoints
      CWE-306: Missing Authentication for Critical Function
Embed Hidden Lockout or Kill-Switch Logic in Rolling-Stock PLC Firmware
  Introduce covert conditional logic that disables rolling stock on a trigger (geofence, timer, date, or remote command)
    Rolling-Stock PLC and Vehicle Control Unit Firmware
      CWE-1242: Inclusion of Undocumented Features or Chicken Bits
      CWE-506: Embedded Malicious Code
      CWE-912: Hidden Functionality
      CWE-923: Improper Restriction of Communication Channel to Intended Endpoints
    Firmware Update and Signing Pipeline
      CWE-347: Improper Verification of Cryptographic Signature
      CWE-494: Download of Code Without Integrity Check
Tamper with Level-Crossing, Wayside and Protection Controllers to Create Hazardous States
  Suppress level-crossing warnings or force unsafe wayside states to endanger road users and trains
    Level-Crossing Controller and Wayside RTU
      CWE-306: Missing Authentication for Critical Function
      CWE-522: Insufficiently Protected Credentials
    Electrical Protection and Traction Power SCADA
      CWE-345: Insufficient Verification of Data Authenticity
      CWE-502: Deserialization of Untrusted Data
Disrupt Operations Through a Compromised Railway SaaS or Third-Party Service Provider
  Halt train operations by taking down a SaaS provider whose availability the railway silently depends on
    Driver / Crew Operational Mobile Application (SaaS-backed)
      CWE-1357: Reliance on Insufficiently Trustworthy Component
      CWE-829: Inclusion of Functionality from Untrusted Control Sphere
    Enterprise Asset Management / Maintenance SaaS
      CWE-287: Improper Authentication
      CWE-502: Deserialization of Untrusted Data
  Use a trusted subcontractor connection to reach railway networks that are not directly exposed
    Third-Party / Subcontractor Network Integration
      CWE-1357: Reliance on Insufficiently Trustworthy Component
      CWE-269: Improper Privilege Management
Encrypt Railway Enterprise and Operational IT for Ransom
  Encrypt crew, scheduling and planning systems to force manual operation and extort payment
    Railway Enterprise IT and Operational Planning Systems
      CWE-308: Use of Single-factor Authentication
      CWE-307: Improper Restriction of Excessive Authentication Attempts
      CWE-732: Incorrect Permission Assignment for Critical Resource
      CWE-693: Protection Mechanism Failure
  Exfiltrate employee and passenger PII for double-extortion leverage
    HR, Payroll and Customer Record Stores
      CWE-311: Missing Encryption of Sensitive Data
      CWE-285: Improper Authorization
Deploy Destructive Wiper Malware Against Railway Operational and Information Systems
  Destroy railway backend data and systems to cause prolonged, non-recoverable disruption
    Railway Backend Servers and Workstations
      CWE-693: Protection Mechanism Failure
      CWE-306: Missing Authentication for Critical Function
      CWE-269: Improper Privilege Management
Compromise the Rolling-Stock and Signalling Software Supply Chain
  Implant malicious or backdoored code upstream so it ships to many operators through trusted updates
    Supplier Firmware Build and Signing Environment
      CWE-494: Download of Code Without Integrity Check
      CWE-321: Use of Hard-coded Cryptographic Key
    Third-Party and Open-Source Component Dependencies
      CWE-1395: Dependency on Vulnerable Third-Party Component
      CWE-829: Inclusion of Functionality from Untrusted Control Sphere
Breach Cloud-Hosted Rail Asset-Management and Analytics Platforms
  Access or manipulate fleet-wide asset-health data in a multi-tenant rail cloud to enable espionage or induce unsafe maintenance decisions
    Rail Asset-Management Cloud Platform (HMAX / Railigent X / HealthHub class)
      CWE-1220: Insufficient Granularity of Access Control
      CWE-285: Improper Authorization
      CWE-287: Improper Authentication
      CWE-778: Insufficient Logging
    Cloud Tenant and Identity Configuration
      CWE-522: Insufficiently Protected Credentials
      CWE-732: Incorrect Permission Assignment for Critical Resource
Hijack Passenger-Facing Digital Services: Ticketing, PIS and Station Wi-Fi
  Deny or degrade online ticketing to cause public disruption and reputational harm
    Online / Mobile Ticketing Platform
      CWE-1333: Inefficient Regular Expression Complexity
      CWE-770: Allocation of Resources Without Limits or Throttling
      CWE-1357: Reliance on Insufficiently Trustworthy Component
      CWE-693: Protection Mechanism Failure
  Deface public information channels to spread propaganda or extremist messaging
    Station Wi-Fi Landing Page and Passenger Information Displays
      CWE-287: Improper Authentication
      CWE-269: Improper Privilege Management
      CWE-345: Insufficient Verification of Data Authenticity
Poison or Evade AI Perception and Inspection Models Used in Rail Safety
  Cause AI perception/inspection models to miss real hazards or report false ones, degrading rail safety at scale
    Onboard / Trackside AI Perception and Inspection Model
      CWE-1039: Inadequate Detection or Handling of Adversarial Input Perturbations in Automated Recognition Mechanism
      CWE-494: Download of Code Without Integrity Check
      CWE-506: Embedded Malicious Code
    AI Training Data and MLOps Pipeline
      CWE-349: Acceptance of Extraneous Untrusted Data With Trusted Data
      CWE-285: Improper Authorization
Abuse LLM-Based Rail Assistants and Agentic Operational Tools
  Manipulate an operational LLM assistant via prompt injection to leak data or drive unsafe actions and recommendations
    LLM Operational Assistant / Maintenance Copilot
      CWE-1427: Improper Neutralization of Input Used for LLM Prompting
      CWE-1426: Improper Validation of Generative AI Output
      CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
    Agentic Tool Connectors and RAG Corpus
      CWE-349: Acceptance of Extraneous Untrusted Data With Trusted Data
      CWE-285: Improper Authorization
Spoof or Jam GNSS Positioning Relied On by Train Location and Operations
  Feed false position, speed or timing into train location systems by spoofing or jamming GNSS
    Onboard GNSS Positioning Receiver
      CWE-345: Insufficient Verification of Data Authenticity
      CWE-290: Authentication Bypass by Spoofing
      CWE-807: Reliance on Untrusted Inputs in a Security Decision
      CWE-349: Acceptance of Extraneous Untrusted Data With Trusted Data
Harvest and Abuse Passenger Biometric, Location and Surveillance Data
  Exfiltrate or abuse concentrated passenger biometric, location and behavioural data for surveillance, profiling or resale
    AI CCTV and Biometric Analytics Platform
      CWE-285: Improper Authorization
      CWE-359: Exposure of Private Personal Information to an Unauthorized Actor
    Passenger Travel-History and App Telemetry Store
      CWE-311: Missing Encryption of Sensitive Data
      CWE-1220: Insufficient Granularity of Access Control
Abuse Insider and Remote-Maintenance Access to Rail Control and OT Networks
  Leverage privileged maintenance or remote-vendor access to reach and manipulate rail control/OT systems
    Remote Maintenance / Vendor Access to OT
      CWE-308: Use of Single-factor Authentication
      CWE-1391: Use of Weak Credentials
      CWE-923: Improper Restriction of Communication Channel to Intended Endpoints
      CWE-269: Improper Privilege Management
    Transient Cyber Assets and Removable Media
      CWE-494: Download of Code Without Integrity Check
Commit Fraud and Account Takeover Against Ticketing and Loyalty Platforms
  Take over passenger accounts and defraud ticketing/loyalty systems for financial gain
    Ticketing / Fare / Loyalty Web and API Platform
      CWE-308: Use of Single-factor Authentication
      CWE-307: Improper Restriction of Excessive Authentication Attempts
      CWE-285: Improper Authorization
      CWE-345: Insufficient Verification of Data Authenticity
    Stored Payment and Identity Data
      CWE-311: Missing Encryption of Sensitive Data